

ICS 33.030
CCS M 21

团体标准

T/TAF 209.1—2024

移动互联网应用程序（APP）合规开发管理 测评规范 第1部分：总则

Evaluation specification for compliance development of mobile Internet
application—Part 1: General principle

2023-02-23 发布

2023-02-23 实施

电信终端产业协会 发布

目 次

前言 II

引言 III

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 1

5 总体原则 1

6 总体要求 2

7 测评方法 2

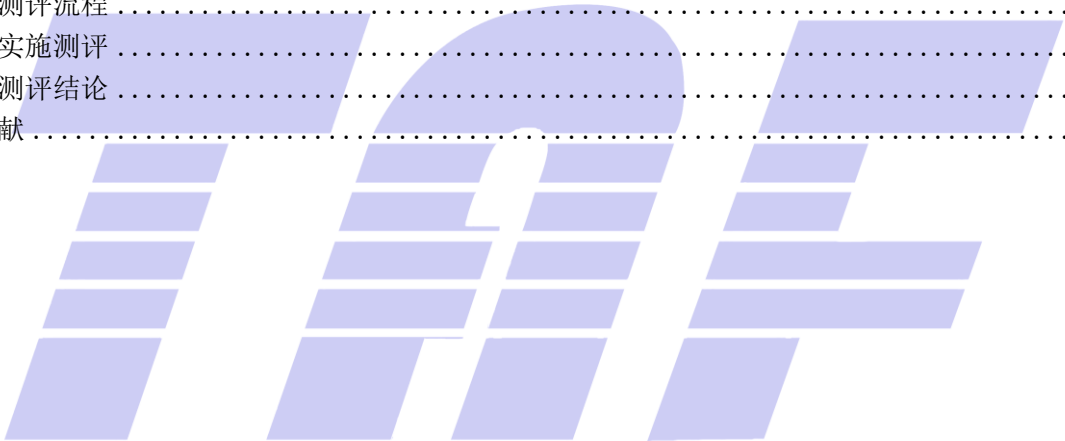
 7.1 测评对象 2

 7.2 测评流程 2

 7.3 实施测评 2

 7.4 测评结论 3

参考文献 4



前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是T/TAF 209《移动互联网应用程序（APP）合规开发管理测评规范》的第1部分。T/TAF 209已经发布了以下部分：

- 第1部分：总则；
- 第2部分：需求设计；
- 第3部分：功能测试；
- 第4部分：代码审计；
- 第5部分：对外接口管理；
- 第6部分：应用编程接口（API）管理；
- 第7部分：更新升级管理；
- 第8部分：数据使用管理；
- 第9部分：算法模型；
- 第10部分：人员能力；
- 第11部分：能力成熟度评估。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由电信终端产业协会提出并归口。

本文件起草单位：中国信息通信研究院、北京快手科技有限公司、蚂蚁科技集团股份有限公司、华为终端有限公司、荣耀终端有限公司、北京微梦创科网络技术有限公司、小米通讯技术有限公司、维沃移动通信有限公司、武汉安天信息技术有限责任公司、联想（北京）有限公司。

本文件主要起草人：落红卫、陈鑫爱、王昕、李实、赵晓娜、林冠辰、任资政、邹庆、王天、姚鹤、赵盈洁、潘洁、李辰淑、张蒋苗、余丽娜、李汝鑫。

引 言

随着个人信息保护、数据安全面临风险的日益增加，以及相关法律法规、标准规范的陆续出台，移动互联网应用程序开发的安全合规至关重要。原有在互联网应用程序开发上线后进行修补的模式已经无法满足日益变化的合规需求，安全合规左移的移动互联网应用程序开发过程成为适应未来合规需要、提升竞争力的必然选择。

合规开发是在开发应用程序的过程中，始终遵守相关法律法规、标准规范和企业规章的开发方式。其价值包括减少法律风险、保障用户权益、降低合规成本和提高产品质量，并为企业赢得更多信任。合规开发本身涉及开发阶段和程序模块众多，来自法律法规、标准规范和企业规章的合规要求持续变化，同时合规开发也是一个持续的过程，在开发完成后，需要不断进行维护和升级。

T/TAF 209旨在对APP开发流程、功能模块、工程管理等提出合规开发管理要求，拟由11部分构成。

- 第1部分：总则。目的在于给出规范移动互联网应用程序（APP）合规开发的总体原则和要求。
- 第2部分：需求设计。目的在于提出规范APP需求设计环节的相关合规开发要求。
- 第3部分：功能测试。目的在于规范移动互联网应用程序（APP）在合规开发阶段满足功能测试的标准要求。
- 第4部分：代码审计。目的在于规范APP代码审计过程，提升代码安全管理能力。
- 第5部分：对外接口管理。目的在于规范APP对外接口的合规开发和使用管理，提升合规能力。
- 第6部分：应用编程接口（API）管理。目的在于规范APP在开发过程中对于API的使用，提升合规能力。
- 第7部分：更新升级管理。目的在于规范APP合规开发在更新升级阶段的要求，提升APP更新升级管理能力。
- 第8部分：数据使用管理。目的在于规范APP在合规开发过程中数据使用的合规管理，提升数据使用合规管理能力。
- 第9部分：算法模型。目的在于规范APP合规开发在算法模型方面的要求，提升APP算法模型开发的合规管理能力。
- 第10部分：人员能力。目的在于规范APP在合规开发过程中的人员能力管理。
- 第11部分：能力成熟度评估。目的在于规范APP在合规开发管理过程中的能力成熟度评估。

移动互联网应用程序（APP）合规开发管理测评规范 第1部分：总则

1 范围

本文件规定了移动互联网应用程序（APP）合规开发的总体原则、技术框架、技术要求和测评方法。

本文件适用于移动互联网应用程序开发者在移动互联网应用程序（APP）时规范其个人信息保护、用户权益保护等方面的合规行为，也适用于监管部门、第三方评估机构等组织对移动互联网应用程序（APP）的合规开发进行监督、管理和评估。

2 规范性引用文件

本文件没有规范性引用文件。

3 术语和定义

下列术语和定义适用于本文件。

3.1

移动互联网应用程序 **mobile Internet application**

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的应用程序。

注：包含移动智能终端预置应用、小程序、快应用以及互联网信息提供者提供的可以通过网站、应用商店等应用分发平台下载、安装、升级的应用程序，简称 APP。

3.2

合规开发 **compliance development**

确保产品或服务开发过程及结果的合法性、安全性、可靠性等方面符合相关要求的活动。

4 缩略语

下列缩略语适用于本文件。

APP：移动互联网应用程序（Mobile Internet Application）

5 总体原则

APP合规开发的总体原则要求如下：

——符合性：保证产品或服务在开发、测试、发布和维护等环节中符合个人信息保护、数据安全、用户权益保护等相关合规性要求，包括APP所在行业的其他合规要求。

- 注：APP所在行业的其他合规具体要求参考相关行业的行政法规与标准规范。
- 安全性：确保开发过程中的代码安全，以及平台、应用程序和系统的安全性，防止恶意攻击和破坏。
 - 透明性：信息详尽、过程透明，记录和标注涉及个人信息保护、数据安全、用户权益保护的重要操作。

6 总体要求

APP合规开发的总体要求包括：

- a) 应指定专门的部门和人员负责 APP 开发过程中的合规安全；
- b) 应在需求设计阶段分析、梳理合规需求，并进行合规风险评估；
- c) 应对 APP 进行个人信息保护、数据安全与用户权益保护等合规功能测试并形成报告，对测试不通过项进行整改；
- d) 应对 APP 代码进行审计，确保 APP 代码的安全合规；
- e) 应区分 APP 的本地 API 和远程 API，确保 API 接口开发、使用的合规性；
- f) 应在 APP 更新升级前进行评估，确保 APP 更新升级后仍满足合规要求；
- g) 应在 APP 开发过程中的重点环节采取技术措施、加强管理，确保 APP 数据使用的合规；
- h) 应在 APP 算法模型的开发过程中，参照相关法规和标准的要求，防范包括算法选择、不当行为等风险；
- i) 应确保开发人员掌握个人信息保护、数据安全和用户权益保护相关的法规和标准要求，具备开展 APP 合规开发所需的知识与技能；
- j) 应从组织与人员、制度与管理、技术与工具等方面持续改进，提升 APP 合规开发能力成熟度。

7 测评方法

7.1 测评对象

测评对象可为APP或者APP中的某项某类功能的开发过程。

7.2 测评流程

测评流程包括确定评估对象、实施测评和测评结论，相关流程见图1。

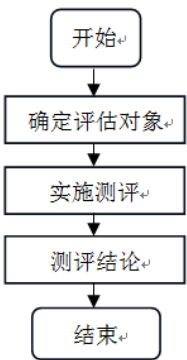


图1 测评流程图

7.3 实施测评

实施测评相关要求包括：

- a) 应依据本文件及本系列其他标准实施测评活动；
- b) 可根据评估对象选择全部或部分系列标准实施测评。

7.4 测评结论

测评结论相关要求包括：

- a) 应记录各测评项测评过程及结果，形成最终测评报告；
- b) 应对测试未通过项的测试过程及未通过原因进行记录和描述。



参 考 文 献

- [1] YD/T 4177 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范
- [2] YD/T 4184 移动互联网应用程序（APP）用户权益保护测评规范
- [3] 关于进一步提升移动互联网应用服务能力的通知（工信部信管函〔2023〕26号）
- [4] DevSecOps: How to Seamlessly Integrate Security into DevOps, Gartner



电信终端产业协会团体标准
移动互联网应用程序（APP）合规开发管理测评规范 第1部分：总则

T/TAF 209.1—2024

*

版权所有 侵权必究

电信终端产业协会印发
地址：北京市西城区新街口外大街 28 号
电话：010-82052809
电子版发行网址：www.taf.org.cn